bigbridge-nl/magento2-stylesmuggler-deferred-directives-fix: README.md

bigbridge-nl/magento2-stylesmuggler-deferred-directives-fix: README.md - Jelle Besseling, Bigbridge.

- Published: date not stated
- Original: <https://github.com/bigbridge-nl/magento2-stylesmuggler-deferred-directives-fix/blob/65aada318afef2b2c037d68e516df2685a50676a/README.md>
- Preserved from: https://github.com/bigbridge-nl/magento2-stylesmuggler-deferred-directives-fix/blob/65aada318afef2b2c037d68e516df2685a50676a/README.md (github-api) on 2026-10-21
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so it remains readable if the page goes offline. To read the original, follow the link above.

Content

> UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

> **Repository reading copy.** Created from README.md.

README.md

`bigbridge-nl/magento2-stylesmuggler-deferred-directives-fix` at `65aada318afe`, path `README.md`.

StyleSmuggler deferred-directives fix for Magento 2

A root-cause patch for the directive-signing flaw behind the StyleSmuggler RCE chain in Magento 2. Built and maintained by Bigbridge, and applied across our client stores.

Adobe's bulletins and the community mitigations harden the exploitation steps. This patch fixes the reason a template directive that arrived through attacker-controlled data is trusted in the first place.

The problem

`Magento\Framework\Filter\Template` filters a template in two passes. In the first it processes every directive it recognises. In the second it processes deferred directives: the ones a child template hands up to its parent because they can only be resolved with the whole

document in hand. `{{inlinecss}}` is the only such case in Magento. CSS inlining has to run on the complete HTML, so a child template returns the directive untouched and lets the parent do it.

To decide which directives were deferred, Magento asked whether processing left the directive unchanged:

```
if ($result['directive'] === $result['output']) {
    // treat as deferred, sign it so the parent will execute it
}
```

That test is also true for any directive the filter could not resolve.

In StyleSmuggler, this problem is exploited to run arbitrary code via the template system.

The official Adobe patch does not close this problem

The fix

Replace the guess with an explicit declaration.

- `Template::deferToParent(string $directive)` records that a directive was deliberately handed to the parent.
- Only recorded directives are signed. The unchanged-output test is kept as a required conjunct, so the set of signed directives is a strict subset of what was signed before. Nothing that was previously unsigned becomes signed.
- `Email\Model\Template\Filter::inlinecssDirective()` declares itself in its `isChildTemplate()` branch, the only deferral in the codebase.
- `filter()` is re-entrant (directives filter their own bodies), so deferrals recorded by an outer invocation are saved and restored around each call.

Two files change: `vendor/magento/framework/Filter/Template.php` and `vendor/magento/module-email/Model/Template/Filter.php`.

What changes at runtime

Measured by driving the real `Framework\Filter\Template` with and without the patch:

Scenario	Before	After
Top-level template, any directive	not signed	not signed
Child template, plain content	untouched	untouched
Child template, declared deferral (`{{inlinecss}}`)	signed	signed

Scenario	Before	After
Child template, unresolvable directive	signed	not signed

Only the last row differs, and that row is the vulnerability.

Templates keep rendering. A `{{template}}` include is processed by the same filter instance, and the CMS and Widget filters both extend the Email filter:

```
Widget\Model\Template\Filter → Cms\Model\Template\Filter → Email\Model\Template\Filter → Framework\Filter\Template
```

Child and parent therefore share a directive set. If the child cannot resolve something, neither can the parent, and the output is the same either way. The asymmetry only exists when content is filtered by the bare framework filter and then embedded in a stronger parent, which is the attack path, not a template-authoring pattern.

Relationship to other mitigations

These cover different layers and do not overlap:

	Covers	Touches
Adobe APSB26-146	check-after-construct in `BlockFactory` / `UrlGeneratorFactory`, report-file execution guards	`module-email` `Preview.php`, `AbstractTemplate.php`
`graycore/magento2-style-smuggler-patch`	DI preference restricting block classes in `blockDirective`, plus template-path and URL-generator plugins	no vendor files, it is a module
This patch	the signing decision itself, so attacker input never gets a signature	`framework/Filter/Template.php`, `module-email` `Filter.php`

There is no file overlap with APSB26-146, and the graycore module overrides only `blockDirective`, not the `inlinecssDirective` this patch touches, so all three can be applied together. We run all three.

Not related: Adobe's 2026-09-001 monthly patch

Adobe's isolated monthly patch 2026-09-001 shipped in September 2026, the same window as this fix, so the two are easy to confuse. 2026-09-001 covers a different set of issues: a missing `ADMIN_RESOURCE` ACL on `Magento_Backup`'s rollback controller, customer and website scope checks in `AddUserInfoToContext`, the import/export file-delete controller,

`InstantPurchase`, a PayPal Express quote-ownership guard, an XSS fix in the admin order-create JavaScript, and repeated-entity decoding in `framework/Escaper.php`.

None of those files is touched by this patch. The StyleSmuggler-adjacent Adobe patch is APSB26-146 in the table above. If you are applying Adobe's September patch, apply it as well as this one; they do not interact.

Which file do I need?

Pick by your `magento/product-community-edition` version.

File	Magento versions
`patches/stylesmuggler-deferred-directives-fix-247-248-249.patch`	2.4.7, 2.4.8, 2.4.9, every patch level
`patches/stylesmuggler-deferred-directives-fix-245-246.patch`	2.4.5 from p1, and 2.4.6, every patch level *

* The patch does not apply to 2.4.5.0 itself: `SignatureProvider` and `FilteringDepthMeter` arrived with APSB22-48 in October 2022, so that release has no signing mechanism for it to change. That says nothing about 2.4.5.0's security otherwise, and it is long past end of support. Every later patch level in both lines applies.

Two variants exist because the 2.4.5 and 2.4.6 lines express the signing block as an inline `foreach` and `str_replace`, where 2.4.7 and later wrap it in `array_unique()` and `applyDirectivesResults()`. The security-relevant code is the same across all of them; only the surrounding context differs, so the hunks need different anchors. Both variants make the same changes: five hunks in `Filter/Template.php` and the one-line declaration in the email filter.

Each file touches two packages. If your patch plugin applies patches per package rather than from the project root, use the pre-split halves in `patches/split-per-package/`, described below.

Applying it

With any Composer patch plugin that applies the files in a `patches/` directory from the project root, drop the file in and let `composer install` apply it. We name our copy after the exact version, for example `patches/StyleSmuggler-deferred-directives-fix-248p5.patch`.

Manually, from the Magento root:

```
git apply --check -p1 patches/stylesmuggler-deferred-directives-fix-247-248-249.patch   # verify first
git apply -p1 patches/stylesmuggler-deferred-directives-fix-247-248-249.patch
```

The paths inside the patch are `vendor/magento/...`, so apply from the project root, not from inside `vendor/`.

If your patcher applies `patches/*` alphabetically, note that this patch goes against pristine vendor code and does not depend on any other patch being applied first.

With cweagans/composer-patches

`cweagans/composer-patches` applies each patch inside a single package's install directory, so it cannot use the combined files at the top of `patches/`. Each one touches two packages (`magento/framework` and `magento/module-email`), and the plugin reports `Could not apply patch! Skipping.`

Use the pre-split halves in `patches/split-per-package/`. Copy the block for your version line:

2.4.7, 2.4.8 and 2.4.9

```
"extra": {
    "patches": {
        "magento/framework": {
            "StyleSmuggler deferred-directives fix": "patches/split-per-
package/stylesmuggler-deferred-directives-fix-247-248-249--magento-framework.patch"
        },
        "magento/module-email": {
            "StyleSmuggler deferred-directives fix": "patches/split-per-
package/stylesmuggler-deferred-directives-fix-247-248-249--magento-module-email.patch"
        }
    },
    "composer-exit-on-patch-failure": true
}
```

2.4.5 and 2.4.6

```
"extra": {
    "patches": {
        "magento/framework": {
            "StyleSmuggler deferred-directives fix": "patches/split-per-
package/stylesmuggler-deferred-directives-fix-245-246--magento-framework.patch"
        },
        "magento/module-email": {
            "StyleSmuggler deferred-directives fix": "patches/split-per-
package/stylesmuggler-deferred-directives-fix-245-246--magento-module-email.patch"
        }
    },
    "composer-exit-on-patch-failure": true
}
```

Both halves are required; applying only one leaves the fix incomplete. The halves keep the `vendor/magento/...` paths, which the plugin resolves through its `-p4` fallback, so nothing needs rewriting.

Keep `composer-exit-on-patch-failure` in there. Without it a failed patch only prints `Could not apply patch! Skipping.` and `composer install` still exits `0`, which can leave a store silently unpatched. `COMPOSER_EXIT_ON_PATCH_FAILURE=1` does the same thing.

Verification

Both variants are in production use across our client stores. Every store was verified by a real `composer install --no-dev`, so the patch was applied by the patcher exactly as a deploy would, on top of the existing APSB26-73, -92 and -146 patches.

Verified end to end on 2.4.5-p14, 2.4.6-p15, 2.4.7-p10 and 2.4.8-p5, and on a clean 2.4.9 install.

Credits

Written by Jelle Besseling at Bigbridge, and first published as this gist before being packaged into this repository.

License

MIT, see LICENSE.

Archived from https://github.com/bigbridge-nl/magento2-stylesmuggler-deferred-directives-fix/blob/65aada318afef2b2c037d68e516df2685a50676a/README.md. Rendered offline from the local Markdown copy.